REFERENCE · REGULATION (EU) 2024/2847

The EU Cyber Resilience Act on a page

CE marking for cybersecurity: every product with digital elements sold in the EU.

Facts as at 30 Oct 2026 · Prepared by [Advisor]

01 · WHEN

Reporting has applied since 11 Sep 2026; everything else applies from 11 Dec 2027

Facts as at 30 Oct 2026

18 months	3 months	3 months	12 months	Full application
10 Dec 2024	**11 Jun 2026**	**11 Sep 2026**	**9 Dec 2026**	**11 Dec 2027**
Entry into force	**Notified-body rules apply**	**Art 14 reporting applies**	**Product liability rules apply**	**Everything else applies**
Regulation (EU) 2024/2847	Member States to 'strive' for enough bodies by 11 Dec 2026	All in-scope products, including those already sold	Software is a product; a vulnerability can be a defect	CE marking and fines; earlier units only if substantially modified

02 · SCOPE

Almost every connected product is in scope

Three tests, all required (Art 2(1)): a product with digital elements · made available in a commercial activity · with a direct or indirect data connection.

IN SCOPE

- Hardware and software, including separately sold firmware, libraries, SDKs and chips
- Companion apps and manufacturer-built backends a function needs (remote data processing)
- Free or B2B-only products supplied commercially
- Offline software on a networked host

OUT OF SCOPE

- Medical and IVD devices, type-approved vehicles, certified aviation, marine equipment
- Products made only for national security or defence
- Identical spare parts; internal tools never placed on the market
- Websites and SaaS used only in a browser, unless a product's backend
- Open source that its publisher does not monetise

Units placed before 11 Dec 2027 need not meet Annex I unless substantially modified, but Art 14 reporting covers them all (Art 69).

03 · ROLES

The brand owner carries almost every duty

Manufacturer · develops or has a product developed and markets it under its own name; Arts 13–14

Importer · EU-based; places non-EU-branded products; checks conformity and documents (Art 19)

Distributor · checks CE marking and documents; withholds non-conforming products (Art 20)

Authorised representative · optional; holds the DoC and file for 10 years; no design duties (Art 18)

Open-source steward · sustains FOSS for commercial use; light duties, no CE marking, no fines (Art 24)

Selling under your own brand, or substantially modifying a product, makes you its manufacturer (Arts 21–22).

04 · CLASSES AND ROUTES

Class decides whether you may self-assess

Default — **A**

Everything not listed in Annexes III–IV: self-assessment

Important · Class I · 19 categories — **A*** | **B+C** | **H**

*Self-assessment only with a cited harmonised standard applied in full; otherwise a notified body

e.g. browsers, password managers, VPNs, operating systems, routers, switches, smart locks, cameras, health wearables

Important · Class II · 4 categories — **B+C** | **H** | **Cert**

A notified body, or EU certification at 'substantial' once a scheme is recognised

Hypervisors and container runtimes; firewalls, IDS and IPS; tamper-resistant microprocessors and microcontrollers

Critical · 3 categories — **Cert**

EU certification if an Art 8(1) act requires it (none adopted); otherwise as Class II

Hardware devices with security boxes; smart meter gateways; smartcards and secure elements

A internal control · **B+C** type examination, then conformity to type · **H** full quality assurance · **Cert** EU certification

⚠ **STATUS AS AT 30 OCT 2026**

No harmonised standard cited; no notified body in NANDO at the 8 Sep 2026 check: important and critical products cannot yet be assessed.

05 · PENALTIES

Fines reach EUR 15m or 2.5% of turnover

EUR 15m or 2.5%	Annex I essential requirements and manufacturer duties (Arts 13–14)
EUR 10m or 2%	Other duties, e.g. importers, DoC, CE marking, technical file
EUR 5m or 1%	Incorrect or misleading information to authorities or notified bodies

Of worldwide annual turnover, whichever is higher (Art 64). No fines for stewards, or for micro and small firms missing a 24-hour deadline.

06 · ESSENTIAL REQUIREMENTS

Build in 13 properties, then run 8 processes

ANNEX I PART I · THE PRODUCT

Each applies as the cybersecurity risk assessment decides.

a	No known exploitable vulnerabilities
b	Secure by default, with reset to original state
c	Security updates, automatic by default with opt-out
d	Access control; report unauthorised access
e	Confidentiality of data, e.g. by encryption
f	Integrity of data, commands, code and configuration
g	Data minimisation
h	Availability of essential functions; DoS resilience
i	Limited impact on other devices and networks
j	Limited attack surfaces, including interfaces
k	Exploit mitigation to reduce incident impact
l	Security logging and monitoring, with opt-out
m	Secure deletion and transfer of user data

ANNEX I PART II · FOR THE SUPPORT PERIOD

1	Identify components and vulnerabilities (SBOM)
2	Remediate without delay; separate security updates
3	Test and review security regularly
4	Disclose fixed vulnerabilities publicly
5	Enforce a coordinated disclosure (CVD) policy
6	Share vulnerability information; publish a contact
7	Distribute updates securely and promptly
8	Free security updates, with advisory messages

SBOMs go in the technical file; they need not be public.

07 · MANUFACTURER DUTIES

Evidence every version; keep it 10 years

Risk assessment, kept up to date	13(2)–(4)
Due diligence on all components, incl. FOSS	13(5)
Support period of at least 5 years*	13(8)
Each update kept available for 10 years	13(9)
Technical file (Annex VII), DoC, CE marking	13(12)
Keep the file and DoC for at least 10 years	13(13)
User information, end-of-support date	13(18)–(19)

*Shorter only if expected use is shorter (Art 13(8)).

08 · REPORTING

Early warnings are due within 24 hours

Actively exploited vulnerability

24 h	→	72 h	→	14 days
Early warning		Notification		Final report after a fix or mitigation

Severe incident

24 h	→	72 h	→	1 month
Early warning		Notification		Final report after the notification

Clocks run from awareness. File on ENISA's Single Reporting Platform to the coordinator CSIRT of the main-establishment Member State; inform affected users (Art 14).

09 · ACT NOW

Five moves to make now

1. **Make reporting ready**
   Register at least two people on ENISA's platform, fix the coordinator CSIRT, staff 24/7 triage and drill a weekend case.
2. **Inventory and classify**
   List every product, version, variant, app and backend; record scope, class and conformity route per SKU.
3. **Book notified-body capacity**
   Pre-contract candidate bodies for important and critical products: capacity, not engineering, sets the critical path.
4. **Build once, apply per product**
   One PSIRT and disclosure policy, build-time SBOMs, signed updates and an evidence system kept for 10 years.
5. **Keep a Module A record for every product**
   A complete Annex VII file and risk assessment: the fallback route, and the notified body's application pack.

Sources: Regulation (EU) 2024/2847; Implementing Regulation (EU) 2025/2392; Commission guidance C(2026) 5252 (formal adoption pending) and FAQ v1.4; ENISA SRP guidance.

A summary for orientation, not legal advice

PROJECT RAMPART ON A PAGE · EXAMPLE GROUP (ILLUSTRATIVE)

The CRA turns product cybersecurity into a licence to sell in the EU.

Example Group can be ready by 11 Dec 2027, but only if it secures third-party assessment capacity and builds shared compliance infrastructure in the next two quarters.

PROGRAMME STATUS **Amber**

Reporting on track; market access at risk: no CRA notified body designated at 8 Sep 2026 checks (external).

Illustrative engagement

Issued 31 Oct 2026 · Board 19 Nov 2026

1 **Reporting is already law.** Every in-scope product, legacy included, is on a 24-hour clock today; the first drill filed its early warning in 9h 40m.

2 **Market access is the binding constraint.** Seven families need a notified body or a cited harmonised standard; neither exists today.

3 **Compliance is an evidence system, not a project.** Build once, apply per product version, and keep the evidence for ten years.

01 · THE NUMBERS

387 days to keep EUR 807m of EU revenue on sale

387 days

from the board on 19 Nov 2026 to full application on 11 Dec 2027

EUR 807m

EU revenue in scope: 13 product families, 55 SKUs (EUR 824m EU revenue in total)

EUR 468m

needs a notified body: 7 families; 58% of in-scope EU revenue, 39% of group revenue

EUR 30m

maximum fine in the top tier: 2.5% of EUR 1.2bn worldwide turnover (Art 64(2))

44% ready

70% 90%

baseline index, 28 Oct 2026; targets 70% by Jun 2027, 90% by Nov 2027

EUR 9.3m

one-off to Dec 2027 incl. 15% contingency; range EUR 7.9m–11.4m; 0.77% of one year's revenue

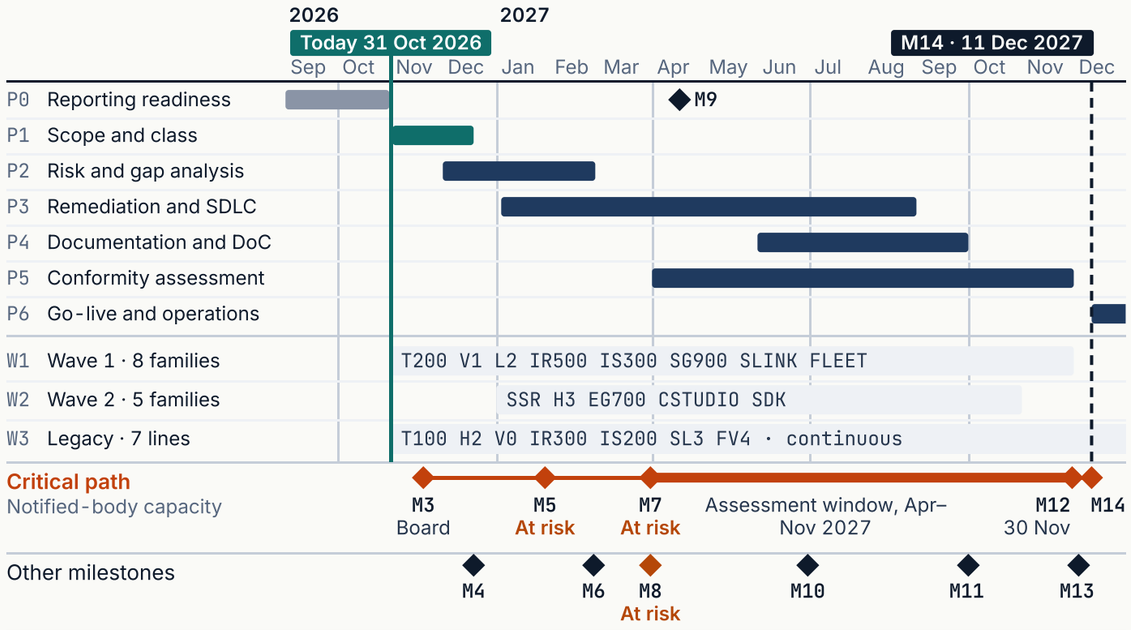
EUR 1.8m a year

to run from 2028 (base case)

Source: business case (base case), scope register, readiness diagnostic, Oct 2026; Illustrative

02 · ROADMAP

A 14-month, three-wave plan; notified-body contracts by Q1 2027 are the critical path



Complete · In progress · Planned · Milestone · At risk · Critical path · Today · Deadline

M3	19 Nov 2026	Board decisions BD1–BD5
M4	18 Dec 2026	Scope and class register baselined
M5	29 Jan 2027	Pre-assessments contracted · At risk
M6	26 Feb 2027	Wave 1 risk assessments signed
M7	31 Mar 2027	Notified bodies contracted · At risk
M8	31 Mar 2027	SBOM pipeline live, Wave 1 · At risk
M9	16 Apr 2027	Second Art 14 drill
M10	30 Jun 2027	Update infrastructure hardened
M11	30 Sep 2027	Wave 1 technical files complete
M12	30 Nov 2027	Module H approval, B certificates
M13	3 Dec 2027	Declarations signed; CE marking
M14	11 Dec 2027	Full application of the CRA

Source: Project Rampart plan, SteerCo #1, 30 Oct 2026; Illustrative

03 · GOVERNANCE

Three decisions cannot wait for a committee

REPORT

PSIRT lead, 24/7

Files the 24-hour early warning without prior approval; legal reviews the 72-hour report.

ACCEPT RESIDUAL RISK

Product security officer

Cost, risk appetite and commercial strategy are not grounds; appeals go to the sponsor (BD4).

SIGN THE DECLARATION

CEO or written delegate

Signs on a checklist the compliance lead counter-signs; the CTO is accountable executive (BD2).

04 · BASELINE

Readiness is 44%; documentation and conformity lag

Family	Class	Governance	Scope & class	Risk & design	SDLC & testing	SBOM & supply chain	Vulnerability handling	Updates & support	Art 14 reporting	Documentation & DoC	Conformity & access	Index
T200	Def	1.75	1.50	2.00	1.00	1.25	0.50	1.75	2.00	1.00	1.00	46%
SSR	Def	1.75	1.00	1.25	1.00	0.50	0.75	2.00	2.00	0.50	0.50	38%
H3	Def*	1.75	0.75	1.25	1.00	0.50	1.00	1.75	2.00	0.75	0.50	38%
V1	I	1.75	1.25	1.50	1.00	1.00	0.50	1.75	2.00	0.50	0.25	38%
L2	I	1.75	1.00	1.25	1.00	0.50	0.75	1.50	2.00	0.50	0.25	35%
IR500	I	1.75	1.50	1.50	2.50	1.00	1.75	1.75	2.25	0.75	0.25	50%
IS300	I	1.75	1.75	1.50	2.50	1.25	1.75	1.50	2.25	1.00	0.50	52%
EG700	Def*	1.75	1.50	1.75	2.00	1.00	1.75	1.75	2.25	0.50	0.50	49%
SG900	II	1.75	1.25	2.00	2.50	1.25	2.00	1.25	2.25	1.00	1.00	54%
SLINK	I	1.75	1.50	1.50	2.25	1.50	1.75	1.75	2.25	0.75	0.75	52%
FLEET	I	1.75	1.75	1.00	1.75	1.25	0.75	1.00	2.25	0.50	0.25	41%
CSTUDIO	Def	1.75	1.75	1.00	1.75	1.75	1.00	0.50	2.25	1.00	0.25	43%
SDK	Def	1.75	1.00	0.75	1.50	2.00	0.75	0.50	2.25	0.75	0.25	38%
Portfolio		1.75	1.35	1.40	1.67	1.13	1.15	1.44	2.15	0.73	0.48	44%
Readiness		58%	45%	47%	56%	38%	38%	48%	72%	24%	16%	

0 Not started · 1 Initial · 2 Defined · 3 Implemented (target) · 4 Assured

Average level 0–4, coloured by level reached; Def* = borderline class under legal review. Source: Readiness Diagnostic, 28 Oct 2026; Illustrative

05 · TOP RISKS

Five high risks, each with an owner

R01	**No notified-body capacity in time** Head of quality & regulatory · pre-contract three bodies	20	Rising
R02	**Engineering capacity vs 2027 roadmap** CTO · ring-fence 26 FTE-years in the 2027 plan	16	Stable
R03	**No harmonised standard cited for Class I** Compliance lead · plan Class I on third-party routes	12	Stable
R04	**SBOM and supplier transparency gaps** Head of platform engineering · binary SCA on firmware	12	Stable
R05	**Legacy lines still sold after 11 Dec 2027** BU president IC · withdraw IR-300 and IS-200 (BD5)	12	New

Score = likelihood × impact; 12+ is high. Source: risk register; Illustrative